

Pilot readiness plan

Not the backlog. See [BACKLOG.md](#) for open work; every finding below is a Tier I row there, and that row is where status lives. This document is the plan for taking CareMetric CareBase into its first real facilities: what "pilot-ready" means, what was found on the way, what was fixed, and the order of everything else. It is the pilot-bar companion to [GO_LIVE_READINESS_REVIEW_PLAN.md](#), which holds the general-availability bar and is not repeated here.

Prepared: 2026-09-04 (second pass, evening UTC), against `main @ efbea07` — PR #483 merged at 14:05 UTC and deployed by run #176 at 14:17 UTC — and the production project `xsqobvvreaovwibxwyvv`. Everything in section 3 was observed after that deploy, so it describes the deployment the first pass produced, not the one it reviewed.

How this pass differed from the first. The morning pass reviewed the operational layer and fixed what it could from the repository. This pass ran the automated gates on the pinned toolchain (including the database lane on a clean local stack), re-probed production after the deploy, and then read the application area by area for functional defects — the workflows a facility would hit in its first two weeks — rather than for configuration. Eight areas were read in parallel by independent reviewers with the same brief; every finding they returned that is called "verified" below was confirmed against the source, and the three most consequential were reproduced on the local stack before being fixed. Findings the reviewers themselves marked uncertain are labelled PLAUSIBLE and carry what would confirm them.

Contents

- | | |
|---|--|
| 1. Verdict | 5. What the review did not reach |
| 2. What "pilot-ready" means | 6. Sequence |
| 3. Ground truth captured this pass | 7. Pilot-specific workflow scripts |
| 3.1 Automated gates, run here on the pinned toolchain | 8. Facility onboarding runbook |
| 3.2 Production, after the 14:17 UTC deploy | 9. Daily pilot checks (owner, about fifteen minutes) |
| 3.3 Review coverage | 10. Pilot go / no-go |
| 4. Findings | 11. Exit to general availability |
| 4.1 Fixed in this change set | Appendix A — What was run in this pass |
| 4.2 P0 and P1 — close before a facility signs in | Appendix B — Tier I map |
| 4.3 P2 — during the pilot, before general availability | |
| 4.4 Carried from the first pass — unchanged, still needed | |
| 4.5 P3 — later, recorded so they are not rediscovered | |
| 4.6 Hygiene | |

1. Verdict

Not ready to put a real facility on it today; ready in roughly three weeks of single-threaded work if section 6 is followed in order.

The base is strong and got stronger this morning: every automated gate is green on the pinned toolchain, all 613 migrations replay from empty, 3,416 pgTAP assertions, 1,699 unit tests and 258 edge-function tests pass, and six of the ten blockers from the first pass are closed and deployed.

What this pass found is a different class of problem, and the reason a functional review was worth doing after the operational one:

- **The first certificate ever issued on production could not render its PDF.** A read added on 2026-08-30 hits three tables the service role was deliberately narrowed off in July. Five attempts, five `permission denied`, error stored as `[object Object]`, job exhausted, and the health check that had just gone green for the first time went red again. No gate covers PDF rendering. **Fixed and queued in this change set (I1).**
- **The import control plane trusted every caller and refused its real users.** A `current_user` test inside a SECURITY DEFINER function is always the owner, so an `employee` could start import jobs in any organization and write ledger rows on other tenants' jobs — reproduced on the local stack — while an org admin's own CSV import failed with "Organization is required". **Fixed, with 18 assertions pinning both directions (I2).**
- **The day a trial ends, the page that sells a plan is unreachable.** `/app/billing` was not a core route, so the lockout had no exit. **Fixed (I3).**
- Beyond those, the area reviews returned **eleven more P1 clusters** that a pilot facility would meet in its first weeks — offline care notes deleted before they sync, an invitation revoke that revokes nothing, an MFA lost-device path that ends in a lockout, a background refetch failure that blanks the app mid-form, incident deadlines computed on an unsourced two-hour window, work items that never close — and the durable import worker itself writes to tables the service role cannot write. None is a rewrite; all are listed with a fix in section 4 and sequenced in section 6.

The four operational blockers from the first pass (Stripe secrets, MFA enrolment, Auth dashboard hardening, DHS re-attestation) are unchanged and still need a person with a console. Stripe is explicitly **not** on the pilot's critical path (section 2).

2. What "pilot-ready" means

The pilot is one to three Pennsylvania personal-care facilities, on the order of 60 staff and 50 residents in total, using CareBase for real work: real staff logins, real residents (PHI under an executed BAA), real incidents and real state forms. It is comped — no money moves — and the owner is the support desk. That is a narrower bar than the general-availability bar in the go-live plan, and it is worth writing down which parts of that bar move and which do not.

Non-negotiable for the pilot (each has a gate in section 8):

#	Requirement	Why it cannot slip
P1	A facility can be created, its admin can sign in with MFA, invite staff, and every invited person can log in from the device they actually use	Identity failures are unrecoverable in front of a customer
P2	The Train loop works end to end including the certificate PDF : assign, complete, verify, download	The certificate is what a surveyor asks to see; it is the product's first deliverable
P3	Email and SMS reach real inboxes and phones from production, and a forced failure reaches the owner out of band	Every reminder, escalation and alert depends on it; nothing has ever been delivered

#	Requirement	Why it cannot slip
P4	Offline care documentation survives a weekend and syncs; nothing a caregiver wrote is silently lost	It is care documentation; loss is a compliance event, not a bug
P5	Tenant boundaries hold for every role, including through imports, exports, guest links and the service role	A regulated product does not get a second chance here
P6	Exclusion screening runs against a current LEIE, and the pages say which sources ran	On-hire screening is on for everyone; screening against a two-month-old list is a false assurance
P7	Reportable-incident deadlines and state forms match the regulation the product cites	A wrong deadline on a surveyor-facing log is worse than no deadline
P8	A backup has been restored once, and there is a one-page incident runbook	The gap that only matters once
P9	The BAA, Terms and Privacy language are executed and confirmed by counsel	PHI without paper is a liability, not a pilot
P10	The owner can see a critical job fail without looking, and the health check can be green	The first pass's thesis: a signal that is always red is no signal

Deliberately not required for the pilot (record the decision, then move on): live Stripe (comp the pilot organizations by hand; keep H9 for GA), SAM.gov (decide LEIE-only for the pilot and say so on the screening pages), SG-2 activation (the copilot stays a drafting aid), real SCORM vendor packages, multi-state rule packs, the export worker's memory ceiling, HSTS preload, unused index cleanup, and the P3 long tail in section 4.5.

3. Ground truth captured this pass

3.1 Automated gates, run here on the pinned toolchain

Gate	Result	Notes
<code>pnpm install --frozen-lockfile</code>	Pass	Node 24.15.0, pnpm 11.13.0, Deno 2.5.6 installed via <code>scripts/setup-codex-cloud.sh</code>
<code>pnpm run typecheck</code>	Pass 0 errors	CareBase, scripts, voice-gateway
<code>pnpm run test</code>	Pass 168 files / 1,699 tests	
14 static checks + self-tests	Pass	source-integrity, migration-policies, edge-function-auth, raise-arity, database-types-format, journey-coverage 12/12, date-only-parsing, planning-registers, dormant-rpcs, unrendered-hooks, server-route-links, frontend-route-links, rpc-call-signatures, query-invalidations
<code>pnpm run check:edge-functions</code>	Pass 258 tests	<code>deno check</code> across 73 functions

Gate	Result	Notes
<code>node scripts/check-dependencies.mjs (strict)</code>	Pass 0 high / 0 critical	4 low/moderate; the nightly issue #482 should self-close on the next run against efbea07
<code>node scripts/check-dhs-sources.mjs</code>	Fail	53 days since the 2026-07-13 human review (limit 45); all 37 links resolve. Unchanged: H12
Full migration replay from empty (CLI 2.109.1)	Pass 613 applied	Then 616 with this change set
<code>supabase test db</code>	Pass 146 files / 3,416 assertions	Then 148 files / 3,459 with this change set
<code>supabase db lint --level error</code>	Pass 0 findings	
<code>supabase db advisors --local --fail-on error</code>	Pass 0 errors	37 WARN: 31 <code>multiple_permissive_policies</code> , 6 <code>function_search_path_mutable</code> (the deliberate <code>pa_*</code> helpers)
Generated types vs <code>database.types.ts</code>	Pass byte-identical	via <code>--db-url</code> ; the CLI's <code>--local</code> path could not authenticate in this sandbox
Playwright	Not run not run here	The sandbox cannot start the edge-runtime container (rlimit); CI ran the suite green on <code>main</code> at 14:05 UTC today, and nothing in this change set touches a browser journey

The CLI's own exit codes were non-zero on three green runs because its telemetry shutdown timed out behind the sandbox proxy; the test, lint and advisor output above is the evidence, not the exit code.

3.2 Production, after the 14:17 UTC deploy

Measure	Before (morning pass)	Now
Migrations applied	603	613 , version list md5 matches the repository
Edge functions	73, stamped 08-31	73 ACTIVE , all stamped 2026-09-04 14:17
<code>organization_settings</code> rows	0	2 (H4 backfill landed)
<code>phase1-synthetic-health</code>	never green	green once at 14:22 UTC — the first success in the life of the project — then red again from 14:37 on <code>certificatePdfJobsExhausted: 1 (l1)</code>
<code>exclusion-screening</code> run from 2026-08-12	running	closed as <code>abandoned_run</code> by the reconciler at 14:15 (H6); <code>exclusion_refresh_runs</code> row for that attempt still <code>staging</code> with 0 rows (l27)

Measure	Before (morning pass)	Now
Certificates	0	1, pdf_status = failed, 5 attempts, pdf_last_error = "[object Object]"; certificates bucket holds 0 objects
billing-quantity-sync	circuit open	unchanged (H9)
data-lifecycle / organization-data-export ledgers	none	export worker recorded its first success at 21:30; lifecycle runs at 07:35 UTC tomorrow (expected, H18)
process-credential-renewals	—	144 ticks in 24 h: 141 × 200, 3 × 401 at 07:10, 12:40, 14:10 UTC (I4)
MFA factors / identity policies	0 / 0	0 / 0 (H10)
notification_deliveries (ever)	0	0 (H11, B3)
Storage	"only course-videos public"	no public bucket: course-videos was made private by 20260714233041 and the player signs URLs; the first pass and ARCHITECTURE.md are stale on this (I25)
Postgres errors, 24 h	1 probe	5 × permission denied for table course_assignments (I1), nothing else
Edge 4xx/5xx, 24 h	billing 503 × 24	billing 503 × 24, credential-renewals 401 × 3
Site	up	/health 200 in 0.5 s, HSTS, frame-ancestors 'none', X-Frame-Options: DENY
GitHub	—	0 open PRs; 28 stale [deploy] Production migration/function deploy failed issues from Aug 1–5 still open while every deploy since has succeeded, plus #481 (DHS) and #482 (deps) (I24)

3.3 Review coverage

Eight independent readings, each against the full code path rather than a grep: identity and session; training and learning; resident care, clinical and offline; safety, survey and compliance operations; notifications, billing and background jobs; workforce and screening; application shell, server, PWA and public pages; tenancy, storage, guest surfaces and import/export/lifecycle. Between them they ran 191 additional unit tests, 95 edge-function tests and read the latest definition of roughly 170 SECURITY DEFINER functions, all 20 anon-executable ones, all 27 buckets' policies and all 34 `verify_jwt = false` gates. What each reviewer explicitly did **not** reach is listed with its findings in BACKLOG Tier I so the coverage is known rather than assumed.

4. Findings

IDs are BACKLOG Tier I rows. "Verified" means confirmed against the source by this pass; "reproduced" means executed on the local stack. Severity: **P0** exposes data or blocks the pilot outright; **P1** must close before a facility signs in; **P2** closes during the pilot, before GA; **P3** later.

4.1 Fixed in this change set

ID	What was wrong	What changed	Verification
I1	<code>generate-certificate-pdf</code> reads <code>course_assignments</code> , <code>quiz_attempts</code> and <code>quizzes</code> with the service-role client; 20260711190100 had revoked the service role from all three. Every render died on <code>permission denied</code> ; the worker stored the plain PostgREST error object as <code>[object Object]</code> ; after five attempts the job was exhausted and nothing in the product could requeue it (the runbook's "replay through the control plane" names a control that does not exist)	20260904110000 grants <code>SELECT</code> (only) on the three tables, adds <code>app_private.requeue_exhausted_certificate_pdf_jobs(p_limit)</code> and calls it once at deploy so the exhausted job renders on the next five-minute tick; <code>_shared/errorMessage.ts</code> keeps a PostgREST error legible and the worker uses it at all seven sites	Reproduced on the clean replay (all three grants absent), fixed, 25 pgTAP assertions incl. the synthetic counter returning to 0; 4 Deno tests; deno check
I2	<code>app_private.assert_import_manager</code> and <code>start_data_import_job</code> recognised a trusted worker by <code>current_user_in('postgres', 'service_role', 'supabase_admin')</code> — inside <code>SECURITY DEFINER</code> that is the owner, for every caller. Reproduced: an employee started jobs in its own and another organization and recorded ledger rows on another tenant's job; an org admin's normal import raised "Organization is required" because the trusted branch swallowed the null organization	20260904130000 adds <code>app_private.is_trusted_database_session()</code> (service-role JWT, or a JWT-less <code>postgres/supabase_admin</code> session), rewires both functions, and makes both rollback functions block a ledger row whose target is outside the job's organization before any child delete	Reproduced, fixed, re-run: all three escalations refused with 42501, the admin's import works; 18 pgTAP assertions in both directions, incl. a cross-tenant rollback target left intact
I3	<code>/app/billing</code> was not in <code>CORE_PATHS</code> ; a lapsed trial (every module <code>is_entitled = false</code>) redirected it to <code>/app/help</code> along with everything else, so the "trial ended — choose a plan" page and checkout were unreachable exactly when they mattered	One entry and a test	<code>productModules.test.ts</code> , <code>routeRegistration.test.ts</code>
I4	<code>process-credential-renewals</code> was the only one of 16 edge-function cron entries that hard-coded the project host and read the vault directly behind <code>coalesce(..., '')</code> , so an empty read sent an empty secret and the function answered 401 while <code>pg_cron</code> recorded success	20260904120000 reschedules it through <code>require_functions_base_url()</code> and <code>require_cron_shared_secret()</code> like the other fifteen	pgTAP asserts the command shape and schedule; the three intermittent empty reads are recorded, not explained

Everything above was verified on the clean local stack: 616 migrations replayed, 148 pgTAP files and 3,459 assertions green, lint and advisors clean, generated types unchanged.

4.2 P0 and P1 — close before a facility signs in

ID	Area	Finding (verified unless marked)	Fix, sized
15	Imports, workers	The durable import worker writes tables the service role cannot. <code>process-data-import-jobs</code> updates <code>data_import_jobs</code> and <code>data_import_rows</code> directly (SELECT-only for <code>service_role</code> , and <code>carebase_activation_wave.test.sql</code> pins that as the contract), updates <code>employees</code> (S/I only), inserts and updates <code>residents</code> and <code>resident_assessment_forms</code> (S only), and selects <code>facility_assignments</code> (I only). Every apply the worker attempts for the employees, residents and assessments domains fails at the first ledger write; the credentials, training-record, room, incident and contact domains go through <code>import_apply_*</code> RPCs and survive. Same class, smaller blast radius: <code>process-credential-renewals</code> selects <code>employee_credential_documents</code> (no grant — every OCR submission throws), <code>generate-poc-document</code> updates <code>violation_documents</code> (no UPDATE — regenerating a POC after edits fails), <code>invite-user</code> 's compensating cleanup updates <code>employees</code> , <code>provision-demo-tenant</code> selects <code>facility_assignments</code> (error discarded), and <code>create-billing-session</code> embeds packages (no grant). Production has never run an import (0 jobs), so nothing has failed yet	Two honest options: RPC-ify the worker's four direct writes (matches the recorded contract; M) or grant and change the contract (S, weaker). Recommended: RPCs for the worker, targeted SELECT/UPDATE grants for the four small functions, and a pgTAP assertion per function listing the tables it touches directly, so the next narrowing cannot strand a worker silently. Then run W12 on the demo tenant
16	Offline care documentation	A syncable offline note is deleted before its first sync attempt after a >72 h absence. Both draft lanes purge records older than 72 h from <code>createdAt</code> inside the entries <code>queryFn</code> , and <code>OfflineSyncManager</code> will not run until those queries settle; the purge also re-fires on every window focus. An aide who documents a refusal offline on Friday and reopens the app on Tuesday loses the only copy. Also: no <code>navigator.storage.persist()</code> , so the encrypted store is evictable; unclassified sync errors retry every 5 minutes until that same purge	Purge only after a sync run has completed in the session, age from last attempt not creation, keep an <code>expired</code> review state instead of deleting; request persistent storage on device registration; move a draft to <code>rejected</code> after N non-network failures. S–M
17	Identity	"Revoke invitation" revokes nothing. The auth user and profile are created with their role at invite time; <code>revoke_user_invitation</code> flips the ledger only. The invitee can still set a password from the link or via <code>/forgot-password</code> (recovery confirms an unconfirmed user) and log in as an active <code>facility_manager</code> . Related: the ledger promises 7 days while GoTrue's invite link dies at <code>otp_expiry</code> (hosted default 1 h, not set in <code>config.toml</code>); a pending employee invite reads as "already has portal access"	Deactivate the profile (and null <code>employees.profile_id</code>) inside <code>revoke_user_invitation</code> , or delete a never-confirmed invitee; set <code>otp_expiry</code> deliberately and make the ledger and the reset-page copy say the true lifetime. S
18	Identity	MFA lost-device is a logout with no product path. No RPC, function or admin page removes a factor; GoTrue refuses self-unenrol at AAL1; the gate blocks every route but <code>/account/security</code> . B6 assumed "the second platform admin removes the factor" — only the Supabase dashboard can. Also: a privileged session silently expires after <code>max_privileged_session_minutes</code> with no re-authenticate prompt; impersonation cannot be exited after 30 minutes; a server-initiated <code>SIGNED_OUT</code> leaves the platform admin's origin tokens and the PHI cache in the tab	Platform-admin, AAL2-gated, audited <code>reset_mfa</code> in <code>admin-update-user</code> plus a control on the user page; a re-authenticate prompt on the fresh-AAL2 403; skip the expiry check on impersonation end; call <code>clearLocalSessionState()</code> on <code>SIGNED_OUT</code> . S–M. And write the recovery drill into the runbook before the pilot

ID	Area	Finding (verified unless marked)	Fix, sized
I9	App shell	A failed background refetch blanks the app and discards unsaved form state. <code>auth.tsx</code> renders <code>AuthProfileError</code> instead of children whenever the profile query is in error — and it is invalidated on every hourly <code>TOKEN_REFRESHED</code> ; the entitlements screen in <code>App.tsx</code> does the same. Three retries in ~3 s on facility wifi is enough. Also: mutations use react-query's default <code>networkMode: "online"</code> , so a save while <code>navigator.onLine</code> is false spins forever and is lost on reload	Gate both screens on <code>isLoadingError</code> , keep last-good data, toast on refetch error; restrict the invalidation to <code>USER_UPDATED</code> ; <code>networkMode: "always"</code> so failed saves reach the existing <code>onError</code> toasts. S
I10	Incidents	Reportable-incident deadlines use an unsourced two-hour window and inconsistent anchors. Presets due death/abuse/neglect/assault at <code>occurred_at + 2 h</code> — the repository's own reading of §2600.16/§2800.16 is 24 hours and the two-hour figure matches the nursing-facility rule, not Chapter 2600/2800. Presets anchor at <code>occurred_at</code> even when reportability is determined days later (instantly overdue, critical alert, printed as missed); manual notifications anchor at "now". The state-form PDF never fills the "reported to Department" fields from the auto-created <code>state_hotline</code> rows, stamps click time as the report time, and its field mapping is unpinned to the real form	Put the window and its citation in the preset table, anchor at time of knowledge, one anchor for both paths; read <code>state_hotline</code> or create <code>licensing_agency</code> ; add a time-of-call input; check in the template's field list and pin the mapping. Confirm the regulation text before choosing. S–M
I11	Work queue	Two work items per POC corrective action, and nothing ever closes an item when its source resolves — incidents closed, violations verified, actions completed, inspections re-done all leave escalated items behind. POC and corrective-action items also come due at UTC midnight, 20:00 Eastern the evening before	Reuse one dedupe key across the sweep and <code>submit_plan_of_correction</code> ; AFTER UPDATE closers on <code>incidents</code> , <code>dhs_violations</code> , <code>corrective_actions</code> , <code>inspection_events</code> ; reset <code>escalated_at</code> when <code>due_at</code> moves; <code>pa_midnight(due_date + 1)</code> as 20260810111000 did for incidents. S–M
I12	Train	A trainer who opens a class for enrolment can never complete it. Check-in needs <code>scheduled/in_progress</code> ; "Complete Class" renders only for <code>draft</code> ; the scheduled-state alternative credits registrations, not QR seat time. Also: an exhausted certificate PDF job answers "Retry PDF" with a misleading 409 and no requeue surface (I1 added the function, not the button); "Assign Training" creates duplicate open assignments	Render Complete Class for <code>scheduled/in-progress</code> (the RPC has no status check); wrap the requeue in an org-admin RPC and change the 409 copy; skip employees with an open assignment. S
I13	Notifications	A provider 5xx is treated as a permanent failure (only 429 retries): a minute of SendGrid 5xx permanently fails the batch, triggers channel fallback and opens the circuit after three runs. <code>unknown</code> outcomes cannot be retried from the UI and reddens the synthetic health check without a time bound. An unconfigured provider is recorded as <code>failed</code> , not <code>skipped</code> as <code>DEPLOYMENT.md</code> says — with SMS enabled by the H4 backfill and Twilio unset, one opted-in user makes every dispatch <code>partial</code> . PLAUSIBLE: the Twilio verifier signs against raw <code>req.url</code> , so if the runtime URL differs from the public one every status callback and every STOP is rejected — confirm with one signed test callback	Retry on <code>429 >= 500</code> ; allow retry of <code>unknown</code> after N hours without a provider event and bound the health counter to 24 h; map <code>provider_not_configured</code> to <code>skipped</code> ; build the Twilio signing URL from the forwarded host or the configured callback URL. S

ID	Area	Finding (verified unless marked)	Fix, sized
I26	Workforce	Approving a shift swap always fails: <code>decide_shift_swap</code> defers a constraint that <code>20260731053000</code> dropped, so every approval raises 42704 (reproduced). An employee cannot submit a credential renewal: both insert policies admit managers only, so <code>/me/credentials</code> is refused by RLS before the RPC that does allow them. The AAL2 wall: with no <code>identity_security_policies</code> row, terminate, transfer, rehire, invite, resend, approve-renewal, HRIS apply and schedule unpublish all require a fresh AAL2 session — so until H10 is done a pilot manager can do none of them, and the roster dialog still offers the fields the trigger refuses. OAPSA provisional deadlines and "not suitable" determinations affect nothing but a badge. PLAUSIBLE: the LEIE matcher screens <code>O'BRIEN/OBRIEN</code> , <code>DELA CRUZ/DELACRUZ</code> and initial-only first names as clear	Delete the <code>set</code> constraints line; owner branches on both policies; H10 then a policy row per pilot organization and read-only lifecycle fields in the dialog; eligibility block and T-7 alert for OAPSA; a normalised-key comparison in the matcher. S–M
I28	Screening	The 2026-09-12 LEIE refresh will start a new run beside the stranded one and most likely die the same way. The LEIE path downloads the whole CSV, holds ~80k rows twice and runs ~81 sequential upserts with no heartbeat, checkpoint or resume after the download; an isolate kill never reaches <code>recordFailure</code> , which is exactly the 08-12 evidence. The SAM path was made resumable on 08-15; this one was not, and is unchanged since the version that died	Read the 08-12 function log first; chunked staging with a heartbeat per batch; a month-derived correlation so a retry replays into the same snapshot; a <code>staging</code> -older-than-N-hours sweep. S–M. Operator half is I27

4.3 P2 — during the pilot, before general availability

ID	Cluster	Findings
I14	Server-side enforcement where the UI is the only gate	POC status ladder writable through PostgREST (<code>status='verified'</code> skips the corrective-action gate); closed incidents can be reopened and their investigation/approval columns set directly; <code>org_admin</code> can hard-delete a resident and the cascade destroys finalized assessment forms and documents; resident evidence documents deletable and one episode pointer is <code>set null</code> ; per-question correctness is revealed after every failed quiz attempt, so an unlimited-attempt final exam can be passed by elimination; the MFA requirement is a React gate only (RLS never checks <code>aal</code>) and the kiosk layout has no gate at all
I15	Resident lifecycle and clinical record	Discharge, hospital transfer and return never supersede scheduled service tasks, so Floor and the offline lane keep accepting documentation for absent or discharged residents; chart domain reads (care plans, progress notes, FHIR meds/allergies, care-level review) select tables directly and bypass <code>clinical_access_log</code> ; the consent gate covers exactly the three designed paths — the AI assessment summary, the assessment PDF and the prefix-based export filter (which misses assessment form content, change events, hospital episodes and offline receipts) are decisions to confirm with counsel
I16	Boundaries and exposure	Organization export ships <code>confidential_incident_details</code> and <code>confidential_reporter_identities</code> without the reviewer gate, AAL2 or an access event; <code>binder-exports</code> and <code>survey-evidence-packets</code> read policies stop at the organization prefix while their RPCs are facility-scoped; two RPCs let an auditor mutate; guest surfaces have no throttle, log no failed attempts, the move-in trio ignores organization suspension, <code>resolve_safety_report_facility</code> 's legacy branch hands the current safety token to any holder of a facility UUID, and <code>verify_certificate</code> discloses the exam score and full name to any slug holder

ID	Cluster	Findings
I17	Jobs control plane	The kill switch is decorative for 20 cron entries that call SQL functions directly, and enabling it on a critical one silences the watchdog while the job keeps running; "Run now" has no dispatch entry for <code>binder-export-generation</code> and <code>document-analyzer-extraction</code> (both now critical — each click records a bogus failed run) or for regulatory polling and credential renewals; <code>analyze-state-form</code> and <code>generate-compliance-binder</code> ignore <code>X-Correlation-Id</code> ; two <code>net.http_post</code> crons are labelled <code>sql_cron</code> and never claim a run; five service-only functions carry the mirror image of I2 (<code>current_user not in (...)</code>) as a guard that can never fire — safe only because their grants are
I18	Compliance calendars	Fire-drill cadence is a 30-day interval, not a calendar month, the six-month sleeping-hours drill is never computed, and Survey Day reads "ready" when no drill program exists; POC "immutable versions" never get their PDF or hash (columns written by nothing); a null <code>poc_due_date</code> silently disables escalation and the digest; an empty declarative policy campaign still spawns a cycle
I19	Build and shell	<code>VITE_DEMO_ACCOUNTS_JSON</code> is inlined into every production bundle and only the UI is hidden without <code>VITE_ENABLE_PUBLIC_DEMO</code> — the build should refuse; the support-ticket rollback is a silent no-op (no delete policy); a redirect loop for a Compliance- or Billing-only organization with no PCH/ALF facility
I20	Learning runtime	SCORM/xAPI completion completes the assignment without a certificate and dead-ends comprehensive courses; the offline course bundle links the raw <code>storage://</code> video locator; the 15-minute signed video URL has no re-sign path (PLAUSIBLE)
I21	Notifications and billing	Recipients come from <code>profiles</code> only — imported staff without a login receive nothing and no <code>skipped</code> row says so; an org admin can opt another user into SMS and the consent is stamped as the recipient's (TCPA); PLAUSIBLE: a <code>checkout.session.completed</code> stub can outrank a later-delivered <code>customer.subscription.created</code> , leaving the subscription without items and the hourly sync <code>partial</code>
I22	Signup and access	The per-email daily signup cap counts failed attempts (three broken tries during an email outage lock a customer out for a day); break-glass grants record evidence but confer no access, though the UI says otherwise

4.4 Carried from the first pass — unchanged, still needed

H9 Stripe (not on the pilot path), **H10 MFA enrolment (on it — P1 above depends on it)**, **H11 Auth dashboard hardening**, **H12 DHS re-attestation**, H13 the non-demo organization's status, H14 AI posture, **H15 backup and restore**, H16 anon-DEFINER justifications, SG-2 (drafting aid at pilot), SG-4 (review by 2026-10-01). Bold ones are on the pilot's critical path.

4.5 P3 — later, recorded so they are not rediscovered

Impersonation banner hidden behind the MFA gate; SCIM endpoint not SCIM 2.0-interoperable; raw Postgres text in `admin-update-user` responses; incident alert text in UTC; kiosk exit needs no credential; seat-time edge cases; `recalculate_course_assignment_statuses` on UTC `current_date`; quiet hours per profile and SMS-only; template variables carrying fallback text; module RLS covering only listed resources; `request-demo` and `email-savings-model` logging raw error objects; render-blocking Google Fonts; `robots.txt` missing two guest paths; unlabelled icon buttons in the incident form; a lazy page's first load hiding the whole shell; a stale shell after a deploy on a >4 s HTML fetch (PLAUSIBLE); in-memory survey packet zips; service-lane replay ignoring a device revocation; `duplicate` discarding a differing offline note; facility transfer not wiping offline drafts; unbounded move-in guest grant expiry; FHIR write-back duplicates on completion failure; `data_lifecycle_policies` permitting `archive_then_delete` on `audit_logs`. All in BACKLOG I23.

4.6 Hygiene

I24 — close the 28 stale deploy-failure issues and, after the next green nightly, #481/#482. **I25** — ARCHITECTURE.md and the first-pass plan still say `course-videos` is public; it has been private since 20260714233041 and the player signs URLs. ARCHITECTURE.md also lists 10 of 73 edge functions and the wrong project name.

5. What the review did not reach

Named so the next reader knows the edges. Not deep-read: complaints, QAPI, emergency operations, the state-forms centre, template documents, the regulatory crosswalk and copilot pages, `/app/today`, the voice gateway service, HRIS staged-row decisions beyond the RPC boundary, the mockup sandbox (non-production). Not executed anywhere: a real Stripe Checkout, a real SendGrid or Twilio delivery, a real HeyGen render, the SCORM bridge against a vendor package, a load test. The Playwright suite ran in CI, not here.

6. Sequence

Single-threaded, in this order, sized in the register's units (S days, M 1–2 weeks). Each block ends with something observed, not something read.

#	Block	Contents	Done when	Size
0	Land this change set	Merge; watch deploy #177; confirm the queued certificate renders (<code>pdf_status = ready</code> , an object in the <code>certificates</code> bucket, the PDF opens and shows the version and score) and <code>phase1-synthetic-health</code> records 24 h of green; confirm one org-admin import starts (<code>start_data_import_job</code> from the Data Import Center dry run)	Green health for 24 h; a rendered PDF; no <code>permission denied</code> in the log	S
1	Close the P1 code list	I5 (worker RPCs + four grants), I6, I7, I8, I9, I10 (after confirming the regulation text), I11, I12, I13, I26, I28 (before 2026-09-12). One pull request per row, each with the pgTAP or unit test that would have caught it, each verified on the clean stack	Every row done with its test named	M
2	Credentials and consoles (the four carried blockers, in pilot order)	H10: enrol TOTP on both platform admins and rehearse the lost-device recovery from I8; H11: leaked-password on, plain email signup off, Site URL and redirects, Send Email hook secret, Turnstile hostname, set <code>otp_expiry</code> deliberately; B3: SendGrid and Twilio secrets, domain authentication (SPF/DKIM/DMARC), register both provider webhooks, send one real email and one real SMS to the owner and follow each row to <code>delivered</code> ; H12: re-verify the 35 DHS form sources and re-stamp; H13: decide the non-demo organization and comp the pilot organizations by hand; H14: set the AI switches to the written posture	Each has a screenshot or a delivery row outside the repository	S–M

#	Block	Contents	Done when	Size
3	Data and alerting	Exclusion screening: reconcile the staging refresh run, "Run now" a fresh LEIE refresh, confirm <code>oig_leie</code> is healthy, decide LEIE-only and make the screening pages say so (I27); force one critical job failure and confirm the owner is paged out of band; add an external uptime check on <code>/health</code> ; verify the Supabase backup setting and restore once into a branch ; write the one-page incident runbook (H15)	LEIE < 45 days old; a phone received an alert; a restore log; the runbook exists	S–M
4	Full gate run and the canary	<code>check:release</code> on the pinned toolchain; the <code>deploy-migrations</code> dry run; then W1 from the go-live plan on production with a real mailbox and phone, followed by the pilot-specific scripts in section 7	Every script passes with a transcript	S
5	Facility onboarding	Section 8, for each pilot facility	The facility's admin has completed the day-1 checklist unaided	S per facility
6	Fourteen-day pilot	Section 9 daily; weekly review of Tier I P2 rows; nothing merges to <code>main</code> without the full lane	Section 10 walked line by line	14 days

Blocks 2 and 3 are console and provider work and can overlap with block 1 only in the sense that they wait on other systems; the owner still does them serially.

7. Pilot-specific workflow scripts

These extend the twelve W-scripts in the go-live plan (section 7 there). Each is run once before the first facility and its transcript kept outside the repository.

ID	Role · environment	Script	Expected
WP1	employee · demo tenant, a phone in airplane mode	Document one service task and one set of vitals offline at 17:00 Friday → close the app → do not open it until Tuesday 09:00 → reconnect → open <code>/me/residents/:id</code>	Both drafts sync from the chart page without navigating; nothing is purged; the receipts ledger shows two <code>applied</code> rows; the panel shows zero pending. (Fails on <code>main</code> today: I6)
WP2	org_admin · demo tenant	Invite a facility manager → revoke the invitation before it is opened → open the original link → try <code>/forgot-password</code> with that address	Both paths refuse; the profile is inactive; <code>employees.profile_id</code> is null. (Fails today: I7)
WP3	platform_admin and org_admin · production, canary organization	Enrol TOTP as the org admin → "lose" the device → platform admin resets the factor from the product → org admin re-enrols → step-up on an irreversible action	No dashboard visit; audit rows for the reset; the step-up prompt observed. (Fails today: I8)
WP4	org_admin · demo tenant	Data Import Center: employees CSV → dry run → apply → close the browser mid-apply → the worker finishes → roll back	The ledger shows the resumed apply; rollback restores the pre-import state. (Fails today: I5)
WP5	trainer · demo tenant	Open a class for enrolment → two staff check in and out by QR → complete the class	Seat time becomes training records. (Fails today: I12)

ID	Role · environment	Script	Expected
WP6	org_admin · demo tenant, mid-afternoon Eastern	Log a reportable incident that occurred yesterday, determined reportable today	The deadline is computed from today and cites the regulation; nothing is instantly overdue; the state-form PDF carries the report time you typed. (Fails today: I10)
WP7	facility_manager and two employees · demo tenant	Publish a schedule → one employee requests a swap → the other accepts → the manager approves; then an employee submits a credential renewal from /me/credentials	The approval succeeds and both shifts move; the renewal lands in the manager's inbox. (Both fail today: I26)
WP8	platform_admin · production, before 2026-09-12	Reconcile the stranded LEIE run → "Run now" the monthly refresh → watch the run heartbeat through staging	A new oig_leie snapshot activates; exclusion_source_health reads healthy; no second staging row is left behind. (At risk today: I27, I28)

8. Facility onboarding runbook

For one facility, owner-run, roughly five working days from "yes" to first real use. Nothing here is customer data; keep the completed checklist outside the repository.

T-10 to T-6 — paper and posture

1. BAA executed both ways (A5); Terms and Privacy confirmed by counsel (N9 in the go-live plan).
2. Decide with the administrator which modules the pilot uses on day one (Train only, or Train + incidents + residents). Fewer is better for week one.
3. Confirm the facility's devices: which PCs, whether staff use personal phones, wifi reliability on the floor. WP1 tells you whether the offline lane is safe to promise.
4. Collect the roster (name, role, email, mobile, hire date) and the resident census in the sample CSV formats from the Data Import Center.

T-5 to T-3 — the organization

5. Create the organization through /signup with the administrator's real mailbox (not by hand): this is the path that stamps trial_ends_at, creates organization_settings and sends the invitation. Then comp it (H13) so the trial clock is irrelevant.
6. Administrator sets a password, enrolls TOTP, and records the recovery contact (I8).
7. Create the facility with the right type (PCH or the stored ALR code, shown as "Assisted Living Facility"); set the facility time zone and clinical enablement.
8. Import employees and residents (I5 must be closed); check the on-hire screening result for each employee cites the LEIE snapshot date (I27).
9. Invite the facility manager and two or three staff first, not everyone: confirm each can log in from their own device, and that each receives the invitation email within two minutes.

T-2 to T-1 — training the trainers

10. Walk the administrator through Today, Work Queue and the Training Matrix on their own screen.

11. Assign one course to the first staff member and have them complete it in front of you: the certificate PDF must be `ready` within five minutes and `/verify/:slug` must resolve.
12. Show the offline lane on a phone (WP1); show `/account/notifications` and get SMS consent from each person who wants texts (I21: the recipient opts in, not the admin).
13. Set the support channel: the owner's phone and email, hours, and what counts as urgent (anything in the Sev-1 list in `PHASE1_OPERATIONS.md`).

T-0 — go

14. Invite the rest of the staff. Assign the annual required courses.
15. Owner watches `/admin/system-jobs` and `/admin/notifications` at the end of the day.

T+1 to T+14 — section 9.

9. Daily pilot checks (owner, about fifteen minutes)

Run every morning; record a one-line result per row outside the repository. Any "no" is a same-day item.

Check	Where	Pass
Critical jobs	<code>/admin/system-jobs</code>	No critical definition stale; no open circuit except billing (until H9); no <code>running</code> row older than its SLA
Synthetic health	<code>/admin</code> health tile	Last run <code>succeeded</code>
Deliveries	<code>/admin/notifications</code>	No <code>unknown</code> older than 24 h; no <code>failed</code> without a retry; yesterday's reminders <code>delivered</code>
Errors	Supabase log stream, 24 h	No Postgres <code>ERROR</code> other than probes; no 5xx from any function except <code>sync-billing-quantities</code>
Client errors	<code>report-client-error</code> ledger	No new report, or each one read and understood
Screening	<code>/admin/exclusion-screening</code>	<code>oig_leie</code> healthy, < 45 days
Offline	<code>offline_draft_receipts</code> , last 24 h	Every device that registered has receipts for what it sent; no <code>rejected</code> without a reason understood
Access	<code>clinical_access_log</code> , sample	Reads match the staff on shift
Facility voice	One call or message with the administrator	Anything confusing, slow or wrong is a Tier I row by evening

Weekly: the Appendix C probes from the go-live plan, the advisor lists, the Tier I P2 review, the audit-integrity reconciliation, and one restore drill of the previous night's backup into a branch.

10. Pilot go / no-go

Go for the first facility requires every line, with evidence named in the BACKLOG row:

1. Section 4.1 deployed and observed (block 0); every P0/P1 row in section 4.2 `done`.
2. H10, H11, H12, H13, H14 and B3 closed; H15's restore rehearsed and both runbooks written.
3. W1 and WP1–WP8 passed on production or the demo tenant as specified, with transcripts.
4. `phase1-synthetic-health` green for 24 consecutive hours; no `system_job_runs` row `running` past its SLA.
5. One real email and one real SMS delivered from production and traced to `delivered`; one forced critical-job failure reached the owner's phone.
6. LEIE active snapshot under 45 days old; the screening pages state which sources ran.
7. The BAA executed for the facility; counsel's confirmation of the clinical-record language on file.
8. The owner has done section 8 steps 1–13 for that facility and the administrator completed step 11 unaided.

No-go conditions during the pilot (stop, preserve evidence, forward-fix, restart the fourteen days): any tenant-isolation failure; any lost care documentation; a certificate issued with wrong content; a notification sent to the wrong person; an incident deadline shown wrong; a Sev-1 per `PHASE1_OPERATIONS.md`.

11. Exit to general availability

When section 10 holds for fourteen consecutive days at every pilot facility, the pilot is over and the bar becomes the go-live plan's section 9: H9 Stripe in test then live, SAM or the recorded decision, the area reviews A–O with their Pass lines, the advisor triage, and the P2 rows in section 4.3 either closed or dated. Nothing in this document needs to be re-dated when that happens; the rows do.

Appendix A — What was run in this pass

All read-only against production; the local stack was the pinned CLI 2.109.1 on Docker 29 (`overlay2`, `-x edge-runtime`, `studio`, `logflare`, `vector`, `imgproxy`).

#	Probe	Result
A1	GitHub Actions: CI on <code>main</code> @ <code>efbea07</code> , deploy #176, nightly advisories, DHS freshness; open PRs; open issues	CI success 14:05; deploy success 14:17; advisories red 09-04 06:44 (pre-merge SHA); DHS red 08-31; 0 PRs; 30 issues (28 stale deploy failures)
A2	<code>supabase_migrations.schema_migrations</code> count, max, md5 vs the repository list	613 / 20260904100000 / identical
A3	<code>list_edge_functions</code>	73 <code>ACTIVE</code> , all <code>updated_at</code> 2026-09-04 14:17

#	Probe	Result
A4	Aggregates: organizations, organization_settings, notification_deliveries, auth.mfa_factors, identity_security_policies, profiles by role, Stripe events, subscriptions, rule packs, certificates, facilities/employees/residents, platform_settings, release_flags, cron.job, buckets and object counts, assignments by status, data_import_jobs, credential_renewal_submissions	Section 3.2
A5	system_job_definitions × latest system_job_runs for the named jobs and every non-closed circuit or non-succeeded run	Section 3.2
A6	exclusion_source_health, exclusion_refresh_runs, the certificate row and its job	LEIE stale since 07-12; refresh run staging, 0 rows; certificate failed × 5
A7	cron.job_run_details 24 h by job and status	All succeeded at the pg_cron level
A8	Log stream 24 h: sources, function 4xx/5xx by function id, Postgres errors, permission denied	Section 3.2
A9	get_advisors security and performance, summarised	524 + 20 *_security_definer_function_executable, 6 search_path, 1 leaked-password, 28 rls_enabled_no_policy (INFO); 31 multiple_permissive_policies, 21 unindexed FKs, 1,451 unused indexes, 1 no-PK backup table
A10	information_schema.role_table_grants / has_table_privilege for service_role across public tables; pg_default_acl; column privileges	70 tables without SELECT for service_role; default ACL grants new tables arwdDxtm to service_role; no column-level grants on the tables in I1/I5
A11	vault.secrets names; require_cron_shared_secret() definition; cron commands using a vault literal or a hard-coded host	cron_shared_secret, supabase_functions_base_url; exactly one entry diverges (I4)
A12	curl /health, root headers, /login title	200, headers as in the first pass
A13	Local: has_table_privilege on the clean replay for I1's tables; the SEC-1 probe script (four tests, transaction rolled back) before and after 20260904130000	Absent / confirmed → present / refused
A14	Local: psql -f for the three migrations; supabase test db targeted and full; db lint; db advisors; gen types --db-url diff	Section 3.1

Appendix B — Tier I map

BACKLOG row	Source findings
I1	certificate PDF grants, requeue, error capture (this pass; TRAIN-1 partial, TRAIN-2 partial)
I2	SEC-1

BACKLOG row	Source findings
I3	JOBS-1
I4	cron entry (this pass; JOBS confirmed)
I5	TRAIN-1
I6	RES-1, RES-2, RES-10
I7	AUTH-1, AUTH-7, AUTH-11
I8	AUTH-3, AUTH-4, AUTH-2, AUTH-5
I9	SHELL-1, SHELL-3
I10	OPS-1, OPS-5
I11	OPS-2, OPS-6
I12	TRAIN-3, TRAIN-2, TRAIN-6
I13	JOBS-3, JOBS-4, JOBS-10, JOBS-2
I14	OPS-3, OPS-4, RES-5, RES-6, TRAIN-5, AUTH-8
I15	RES-3, RES-4, RES-7
I16	SEC-2, SEC-5, SEC-6, SEC-4, RES-12
I17	JOBS-5, JOBS-6, JOBS-14, SEC-3
I18	OPS-7, OPS-8, OPS-9, OPS-11
I19	SHELL-2, SHELL-4, SHELL-5
I20	TRAIN-4, TRAIN-7, TRAIN-8
I21	JOBS-7, JOBS-8, JOBS-9
I22	AUTH-6, AUTH-9
I23	the P3 long tail (section 4.5)
I24	GitHub issue hygiene
I25	documentation drift
I26	WORK-3, WORK-4, WORK-5, WORK-7, WORK-6 (P1); WORK-8 to WORK-16 (P2); WORK-17 to WORK-25 (P3); WORK-2 folds into I7
I27	exclusion screening: the staging refresh run and the LEIE-only decision
I28	WORK-1